Security Policy

Transparency Hub Network Version: 1.0 **Effective Date:** March 5, 2026 **Last Updated:** March 5, 2026 **Owner:** Engineering Team **Classification:** Internal

---

1. Purpose

This Security Policy defines the security principles, controls, and practices that govern the protection of Transparency Hub Network's systems, data, and users. It establishes the organization's commitment to maintaining confidentiality, integrity, and availability of all information assets and services.

---

2. Scope

This policy applies to:

- All information systems, applications, and infrastructure operated by Transparency Hub Network
- All data processed, stored, or transmitted by the platform
- All personnel, contractors, and third parties with access to company systems
- All environments: development, staging, and production

---

3. Security Principles

Principle	Description
Defense in Depth	Multiple layers of security controls across all systems
Least Privilege	Users and systems are granted minimum access necessary to perform their function
Separation of Duties	Critical operations require multiple individuals to complete
Secure by Default	Systems are configured securely out of the box; security is not optional
Zero Trust	No implicit trust based on network location; verify every request
Transparency	Security practices are documented and communicated to stakeholders

---

4. Organizational Security

4.1 Security Governance

- The Engineering Lead serves as the security owner with overall responsibility for information security
- Security decisions are documented and tracked in the project management system
- Security policies are reviewed quarterly and updated as needed
- All team members are responsible for adhering to this policy

4.2 Personnel Security

Onboarding:

- All personnel must review and acknowledge the Security Policy before receiving system access
- Access is provisioned based on role requirements (least privilege)

- Multi-factor authentication (MFA) is required for all accounts

During Employment:

- Security awareness refresher conducted quarterly
- Access reviews conducted every 90 days
- Suspicious activity must be reported immediately

Offboarding:

- All access revoked within 24 hours of departure
- Credentials rotated for any shared resources
- Company data on personal devices wiped or returned

4.3 Acceptable Use

All personnel must:

- Use company systems only for authorized business purposes
- Protect credentials and never share passwords or tokens
- Report security incidents or suspicious activity immediately
- Follow secure coding standards when developing software
- Lock workstations when unattended

Personnel must not:

- Install unauthorized software on company systems
- Bypass or disable security controls
- Access data or systems beyond their authorized scope
- Store company data on unauthorized personal devices or cloud services
- Share sensitive information through insecure channels

---

5. Data Security

5.1 Data Classification

Classification	Description	Examples	Controls
Public	Information intended for public access	Marketing content, public website, documentation	No special controls
Internal	Business information for internal use	Architecture diagrams, internal communications, meeting notes	Access-controlled, not shared externally
Confidential	Sensitive business or personal data	Member PII (names, emails, phone numbers), membership records, meeting minutes	Encrypted at rest and in transit, access-logged, role-based access
Restricted	Highly sensitive data requiring maximum protection	Payment credentials, OAuth tokens, API keys, passwords, financial records	Encrypted, access-logged, rotated regularly, minimal access

5.2 Data Encryption

In Transit:

- All external communications encrypted with TLS 1.2 or higher
- HTTPS enforced on all endpoints (HTTP requests redirected to HTTPS)
- API communications between services use TLS
- Certificate management handled by Azure (automatic renewal)

At Rest:

- Azure Blob Storage: Server-Side Encryption (SSE) with Microsoft-managed keys
- PostgreSQL: Transparent Data Encryption (TDE) enabled
- Application settings and secrets: Azure Key Vault encryption
- Backups: Encrypted using the same standards as primary storage

5.3 Data Retention and Disposal

Data Type	Retention Period	Disposal Method
Member personal data	Duration of membership + 12 months	Secure deletion from database and backups
Payment transaction records	7 years (regulatory compliance)	Archived, then secure deletion
Meeting recordings	12 months after event date	Deleted from Blob Storage
Meeting transcripts and minutes	Indefinite (association decides)	Secure deletion on request
Application logs	90 days (Application Insights) + 1 year (cold storage)	Automatic expiry
Authentication logs	1 year	Automatic expiry

5.4 Data Subject Rights

In compliance with the Nigeria Data Protection Regulation (NDPR) and GDPR principles:

- **Right of Access:** Members can request a copy of their personal data
- **Right to Rectification:** Members can request correction of inaccurate data
- **Right to Erasure:** Members can request deletion of their data (subject to legal retention requirements)
- **Right to Data Portability:** Members can request their data in a machine-readable format
- **Right to Object:** Members can object to certain data processing activities

Data subject requests are handled within **30 days** of receipt.

---

6. Access Control

6.1 Authentication

Control	Implementation
Multi-Factor Authentication	Required for all administrative accounts and infrastructure access
Password Policy	Minimum 12 characters, complexity requirements enforced

Session Management	Access tokens expire after 1 hour; refresh tokens after 7 days
Account Lockout	Account locked after 5 failed login attempts; unlock after 30 minutes or admin intervention
OTP Verification	One-time password required for initial login

6.2 Authorization

- **Role-Based Access Control (RBAC)** enforced at the application level
- Roles: Super Admin, Association Admin, Chapter Admin, Member
- Each role has defined permissions; no implicit access
- Admin actions are logged and auditable

6.3 Application Roles and Permissions

Action	Member	Chapter Admin	Association Admin	Super Admin
View own profile	✅	✅	✅	✅
View chapter members	✅	✅	✅	✅
Manage members	❌	✅	✅	✅
Manage membership types	❌	❌	✅	✅
Manage payment settings	❌	❌	✅	✅
Manage meeting integrations	❌	❌	✅	✅
Create/edit events	❌	✅	✅	✅
View meeting minutes	✅	✅	✅	✅
Edit meeting minutes	❌	✅	✅	✅
Manage association settings	❌	❌	✅	✅
Platform administration	❌	❌	❌	✅

6.4 Infrastructure Access

System	Access Method	Who
Azure Portal	MFA-protected Azure AD accounts	Engineering team
GitHub Repositories	SSH keys or personal access tokens with MFA	Engineering team
Production Database	Azure Portal (no direct connection)	Engineering lead only
Staging Database	Connection string via Azure Functions App Settings	Engineering team
Azure Key Vault	Azure RBAC with access policies	Engineering lead

6.5 Access Reviews

- User access reviewed every **90 days**

- Unused accounts disabled after **60 days** of inactivity
- Service account permissions reviewed quarterly
- Third-party integration access reviewed quarterly

---

7. Network and Infrastructure Security

7.1 Architecture

Transparency Hub Network operates on a Platform-as-a-Service (PaaS) architecture on Microsoft Azure:

Component	Service	Security Controls
Frontend	Azure Static Web Apps	HTTPS-only, managed SSL, DDoS protection
Backend API	Azure Functions	HTTPS-only, function-level auth keys, VNet integration available
Database	Azure Database for PostgreSQL	Firewall rules, SSL enforcement, encrypted at rest
File Storage	Azure Blob Storage	Private access only, SAS tokens with short expiry, encrypted at rest
Secrets	Azure Key Vault	Hardware-backed encryption, access-logged, RBAC
Monitoring	Azure Application Insights	Log analytics, alerting, anomaly detection

7.2 Network Controls

- All Azure services configured with firewall rules restricting access to authorized sources
- No public access to database servers; access restricted to Azure Functions
- Blob Storage containers set to **private** (no anonymous access)
- CORS policies configured to allow only known frontend origins
- Rate limiting enforced on API endpoints (100 requests/minute per user, 10/minute for auth endpoints)

7.3 DDoS Protection

- Azure Static Web Apps includes built-in DDoS protection
- Azure Functions protected by Azure's network-level DDoS mitigation
- Application-level rate limiting provides additional protection

---

8. Application Security

8.1 Secure Development

All software development follows our **Secure Software Development Lifecycle (SSDLC)**, which includes:

- Security requirements gathering during design phase
- Threat modeling for high-risk features (STRIDE methodology)
- Secure coding standards for Python and TypeScript
- Mandatory code reviews with security checklist
- Automated security testing (SAST, DAST, SCA)
- No secrets in source code — enforced by secret scanning

See **SSDLC** document for full details.

8.2 Security Testing

Test Type	Tool	Frequency
Static Application Security Testing (SAST)	GitHub CodeQL	Every PR, push to main, weekly
Dynamic Application Security Testing (DAST)	OWASP ZAP	Weekly, on-demand
Software Composition Analysis (SCA)	GitHub Dependabot	Continuous
Dependency Audit	npm audit / pip audit	On-demand

See **SAST & DAST** document for full details.

8.3 Vulnerability Management

All vulnerabilities are managed according to our **Vulnerability Management Policy**, with defined:

- Severity classification (CVSS v3.1)
- Remediation SLAs (Critical: 24h, High: 7d, Medium: 30d, Low: 90d)
- Lifecycle tracking from detection to closure
- Exception and deferral process

See **Vulnerability Management Policy** for full details.

8.4 API Security

Control	Implementation
Authentication	JWT tokens required on all non-public endpoints
Authorization	Role-based access control checked at controller level
Input Validation	Schema validation on all request bodies
Rate Limiting	100 requests/minute per user; 10/minute for auth endpoints
CORS	Restricted to known frontend origins
Error Handling	Generic error messages; no internal details exposed to clients
Logging	All API requests logged; sensitive data excluded from logs

---

9. Third-Party Security

9.1 Vendor Assessment

All third-party services processing our data must meet these requirements:

Requirement	Details
Encryption	TLS 1.2+ in transit, encryption at rest
Compliance	SOC 2, ISO 27001, or equivalent certification

Data Processing Agreement	Required for services processing member PII
Incident Notification	Must notify us of breaches within 72 hours
Access Controls	Demonstrate role-based access and audit logging

9.2 Current Third-Party Services

Service	Purpose	Data Shared	Compliance
Microsoft Azure	Cloud infrastructure	All application data	SOC 2, ISO 27001, GDPR
Attendee.dev	Meeting bot recording	Meeting URLs, scheduling metadata	Data processing agreement in place
Google Gemini AI	Meeting minute generation	Meeting transcripts	Google Cloud Terms of Service
Stripe	Payment processing (global)	Payment amounts, customer email	PCI DSS Level 1, SOC 2
Paystack	Payment processing (Africa)	Payment amounts, customer email	PCI DSS, NDPR compliant
Google OAuth	Meeting provider authentication	OAuth tokens (managed by Google)	SOC 2, ISO 27001
Zoom	Meeting provider (via Attendee.dev)	OAuth tokens (managed by Attendee.dev)	SOC 2
Microsoft Teams	Meeting provider	OAuth tokens (managed by Microsoft)	SOC 2, ISO 27001
GitHub	Source code hosting, CI/CD	Source code, security alerts	SOC 2, ISO 27001

9.3 Third-Party Reviews

- Third-party security posture reviewed annually
- Vendor security incidents monitored continuously
- Data processing agreements reviewed on renewal

---

10. Secrets Management

10.1 Policy

No secrets in source code. No exceptions.

10.2 Secret Storage

Environment	Storage	Access Control
Local Development	`local.settings.json` / `.env.local` (gitignored)	Developer machine only

Staging	Azure Functions App Settings	Azure RBAC
Production	Azure Key Vault + App Settings	Azure RBAC, access-logged

10.3 Secret Rotation Schedule

Secret Type	Rotation Frequency	Method
Database credentials	Every 90 days	Azure Key Vault rotation
JWT signing keys	Every 90 days	Key Vault rotation
OAuth client secrets	Every 180 days or on compromise	Provider dashboard + Key Vault
API keys (Attendee.dev, Gemini)	Every 180 days or on compromise	Provider dashboard + App Settings
Webhook signing secrets	Every 180 days or on compromise	Regenerate on both sides
Payment gateway keys	Every 180 days or on compromise	Provider dashboard + Key Vault

10.4 Secret Scanning

- GitHub Secret Scanning enabled on all repositories
- Detected secrets are treated as compromised and rotated immediately
- Pre-commit hooks available for local detection

---

11. Incident Response

11.1 Incident Classification

Severity	Description	Response Time	Examples
P0 — Critical	Active exploitation, confirmed data breach, complete service outage	Immediate (< 1 hour)	SQL injection exploited, credentials leaked, ransomware
P1 — High	Vulnerability with high impact, partial service disruption	< 4 hours	Auth bypass discovered, payment processing failure, DDoS attack
P2 — Medium	Vulnerability with limited impact, minor service degradation	< 24 hours	XSS on non-critical page, elevated error rates, single component failure
P3 — Low	Minor security finding, no immediate risk	< 48 hours	Missing non-critical header, informational finding

11.2 Incident Response Process

1. **Detection & Reporting**
    - Incident detected through monitoring, automated alerts, or user reports
    - Incident logged with initial classification
2. **Triage & Assessment**
    - Confirm the incident and assess severity

    - Identify affected systems, data, and users
    - Assign incident owner

3. **Containment**
    - Isolate affected systems if necessary
    - Revoke compromised credentials
    - Apply temporary mitigations (WAF rules, feature flags, access restrictions)
    - Preserve evidence for investigation

4. **Eradication & Recovery**
    - Identify and eliminate root cause
    - Deploy permanent fix
    - Restore normal operations
    - Verify fix effectiveness

5. **Post-Incident Review**
    - Conduct root cause analysis within 5 business days
    - Document lessons learned
    - Update security controls to prevent recurrence
    - Update detection rules and monitoring
    - Communicate findings to the team

11.3 Communication During Incidents

Audience	Channel	When
Engineering team	Direct message / group chat	Immediately on detection
Leadership	Email summary	Within 4 hours for P0/P1
Affected users	Email notification	Within 72 hours if data impacted
Regulatory authorities	Formal notification	As required by NDPR/GDPR

11.4 Incident Log

All incidents are logged with:

- Date and time of detection
- Description and severity
- Affected systems and data
- Response actions taken
- Root cause
- Remediation steps
- Time to detect and time to resolve
- Lessons learned

---

12. Business Continuity and Disaster Recovery

12.1 Backup Policy

System	Backup Frequency	Retention	Recovery Time Objective

PostgreSQL Database	Daily automated	30 days	< 4 hours
Azure Blob Storage	Geo-redundant (automatic)	Continuous	< 2 hours
Source Code	Real-time (GitHub)	Indefinite	< 1 hour
Configuration	Stored in Key Vault + version controlled	Indefinite	< 1 hour

12.2 Recovery Procedures

- Database can be restored to any point within the 30-day retention window
- Blob Storage data is replicated across Azure regions
- Application can be redeployed from GitHub in under 30 minutes
- Runbooks maintained for common recovery scenarios

12.3 Testing

- Backup restoration tested quarterly
- Disaster recovery drill conducted annually
- Recovery procedures reviewed and updated after each test

---

13. Monitoring and Logging

13.1 What We Monitor

Category	Monitored Events	Tool
Authentication	Login attempts, failures, lockouts, MFA events	Application Insights
Authorization	Access denied events, privilege escalation attempts	Application Insights
API Activity	Request volume, error rates, latency	Application Insights
Data Access	CRUD operations on sensitive entities	Application logging
Payments	Transaction success, failure, refund events	Application logging
Infrastructure	Resource utilization, availability, performance	Azure Monitor
Security	CodeQL alerts, Dependabot alerts, ZAP findings	GitHub Security

13.2 What We Never Log

- Passwords or password hashes
- Full credit card numbers or CVVs
- OAuth access tokens or refresh tokens
- API keys or secrets
- Personal data beyond what is necessary for debugging

13.3 Alerting

Alert	Threshold	Action
Authentication failure spike	> 10 failures/minute from single IP	Investigate, potential brute force

Error rate increase	> 5% 5xx errors for 5 minutes	Engineering team notified
Unusual API pattern	Anomalous request volume or path access	Review and investigate
Service availability	Downtime > 2 minutes	Immediate notification
Security scan finding	Any Critical/High severity	Engineering team notified

13.4 Log Retention

- **Application Insights:** 90 days (active), 1 year (cold storage)
- **Security logs:** 1 year
- **Access logs:** 1 year

---

14. Compliance

14.1 Regulatory Framework

Regulation	Applicability	Status
Nigeria Data Protection Regulation (NDPR)	Primary — Nigerian users and data	Compliant
General Data Protection Regulation (GDPR)	International users	Principles followed
Payment Card Industry DSS (PCI DSS)	Payment processing	Handled by Stripe/Paystack (PCI Level 1)

14.2 Published Policies

Document	URL
Privacy Policy	https://transparencyhubnetwork.ai/privacy
Terms of Service	https://transparencyhubnetwork.ai/terms-of-service
SSDLC	GitHub: Transparency-Hub/docs/SSDLC.md
SAST & DAST	GitHub: Transparency-Hub/docs/SAST-DAST.md
Vulnerability Management Policy	GitHub: Transparency-Hub/docs/VULNERABILITY-MANAGEMENT-POLICY.md
Security Policy	This document

---

15. Policy Violations

Violations of this Security Policy may result in:

- Revocation of system access
- Disciplinary action up to and including termination
- Legal action where applicable

All suspected violations must be reported to the Engineering Lead immediately.

---

16. Document Control

Version	Date	Author	Changes
1.0	2026-03-05	Engineering Team	Initial version

This policy is reviewed and updated quarterly, or immediately following a significant security incident, organizational change, or regulatory update.

For questions about this policy, contact: support@transparencyhubnetwork.ai